

the token. Even in this simplified case, where the confidentiality and integrity of algorithms and keys is achieved without operating system support, we will demonstrate that there are still vulnerabilities which may only be effectively addressed with the features of a secure operating system.

One vulnerability in this simplified case is that invocation of the token cannot be guaranteed. Any legitimate attempt to use the token might not result in a call to the token. The application that performs the cryptographic invocation might be bypassed or modified by malicious applications or malicious users. Malicious applications might impersonate the cryptographic token to the invoking application. Mandatory security and protected path features in the operating system address this vulnerability. Mandatory security mechanisms may be used to ensure that the application that invokes the cryptographic token is unbypassable and tamper-proof against both malicious software and malicious users. Unbypassability could also be achieved by using an inline cryptographic token, which is physically interposed between the sender of the data to be protected and the receiver of the protected data; however, this would be less flexible. A protected path mechanism may be used to ensure that malicious software cannot impersonate the cryptographic token to the invoking application. Misuse of the cryptographic token is a second vulnerability in the simplified case. Misuse may involve the use of a service, algorithm, session or key by an unauthorised application. Without operating system support for identifying callers, a cryptographic token can do little more than require that a user activate it, after which, any service, algorithm, session or key authorised for that user may be used by any application on the system. In this case, the cryptographic token may be misused by applications operating on behalf of other users or may be misused by malicious software operating on behalf of the authorised user.

Furthermore, unless the cryptographic token has a direct physical interface for user activation, malicious software can spoof the token to the user, obtain authentication information, and subsequently activate the cryptographic token without the user's